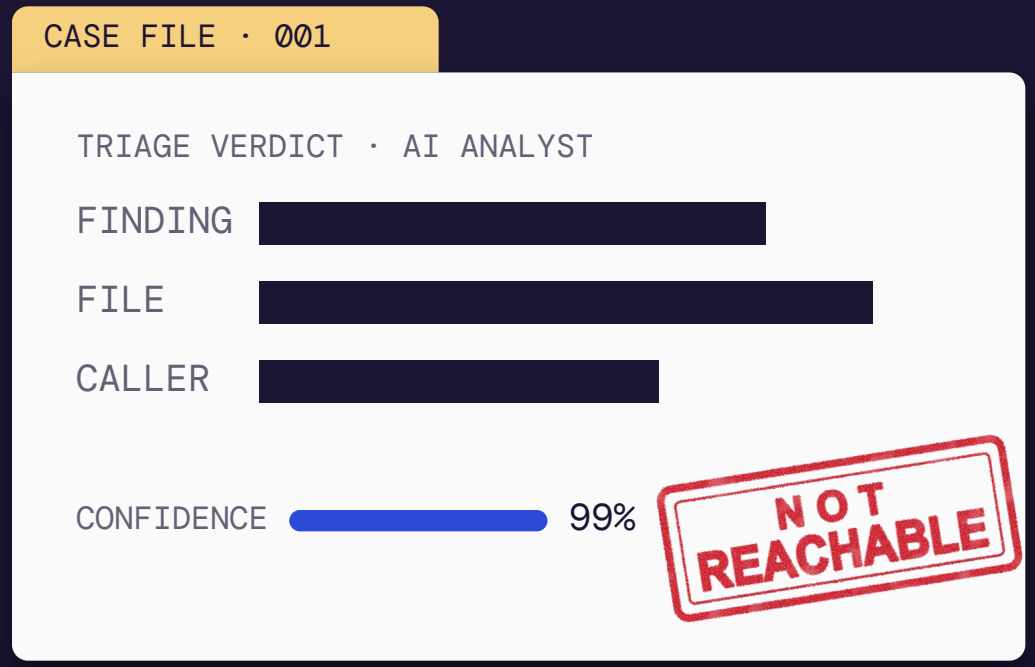
LASCON 2026 · AUSTIN, TX · OCT 30 🎃

Confidently Wrong

Navigating AI Hallucinations in Your AppSec Toolchain

Adam Schaal · Pixee

Confidence: 99%. Accuracy: meh.

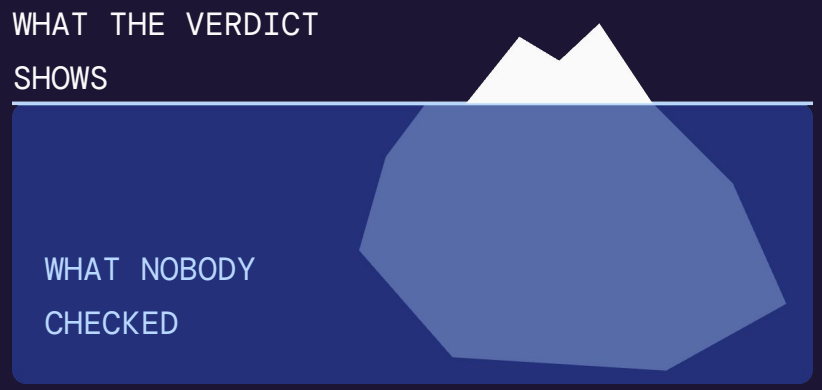


LASCON

PRIOR CONVICTIONS · CASE 1912

Unsinkable, said the experts

20 lifeboats. Room for 1,178. More than 2,200 aboard.



CASE FILE · 1912

WHITE STAR LINE · PRESS STATEMENT · APR 15, 1912

“We place absolute confidence in the Titanic. We believe that the boat is unsinkable.”

It had already sunk.

VESSEL RMS Titanic
SOURCE P.A.S. Franklin, VP, White Star Line

CONFIDENCE Absolute

UNSINKABLE

Sources: The Shipbuilder (1911), “practically unsinkable” · Franklin statement as reported Apr 15, 1912 · Encyclopaedia Britannica, “Titanic”

EXHIBIT B · THE DETECTIVE

PERSONNEL FILE · 004

SUBJECT PROFILE · REAL HUMAN



Adam Schaal

ROLE	AI Security Engineer, Pixee
PRIOR	AWS AppSec, Contrast Security
RECORD	25+ talks, 3 at LASCON
FOUNDED	Kernelcon · DEF CON 402
MODE	Perpetual Builder, Serial Side-Project Starter

calibrated, allegedly

CONFIDENCE 70%

VERIFIED HUMAN

“The failures in this talk are public, and some are my team’s. That’s why I trust them.”

Some you can look up tonight. Some I watched happen.

THE CRIME SCENE · THE PREMISE

Nobody triages this by hand anymore

48,185

CVEs published in 2025. About 132 a day.

Before your own scanners add a single finding.

01 · THE BACKLOG

Outgrew every AppSec team years ago.

02 · THE HIRE

So we brought in an AI analyst to triage it.

03 · THIS TALK

Assumes you run one. Every verdict it gives is a case file. Evidence, or it doesn’t close.

Source: Jerry Gamblin, “2025 CVE Data Review,” Jan 1, 2026 · per-day figure is 48,185 ÷ 365

EXHIBIT A · TRIAGE QUEUE, TUESDAY

Would you close it?

99% sure. Three cited code paths. A tool that has never once expressed doubt in its life.

CASE FILE · 0002

TRIAGE VERDICT · AI ANALYST

“This vulnerability is not reachable.”

ID lodash · CVE-2019-10744 (prototype pollution)

FILE services/billing/src/config/merge.ts

The vulnerable function defaultsDeep is only called from build-time configuration loading. Request bodies are validated and stripped of __proto__ and constructor keys before any merge. No user-controlled object reaches a lodash merge function at runtime.

1 services/billing/src/config/merge.ts:14-22: defaultsDeep(baseConfig, envOverrides)

2 services/billing/src/middleware/sanitizeBody.ts:31-48: (strips prototype keys)

3 services/billing/package.json:27: "lodash": "4.17.11"

CONFIDENCE 99%



EXHIBIT A · REVIEWED

One citation was invented.

Path 2 doesn't exist. The vulnerability is reachable.

> Wrong. It's reachable: routes/invoices.ts:88 passes req.body.preferences straight into defaultsDeep. No such sanitizer exists.

CASE FILE · 0002

TRIAGE VERDICT · AI ANALYST

Wrong. It's reachable.

"This vulnerability is not reachable."

ID lodash · CVE-2019-10744 (prototype pollution)

FILE services/billing/src/config/merge.ts

The vulnerable function defaultsDeep is only called from build-time configuration loading. Request bodies are validated and stripped of __proto__ and constructor keys before any merge. No user-controlled object reaches a lodash merge function at runtime.

THIS FILE DOES NOT EXIST

1 services/billing/src/config/merge.ts:14-22: defaultsDeep(baseConfig, envOverrides)

2 services/billing/src/middleware/sanitizeBody.ts:31-48: (strips prototype ke…

3 services/billing/package.json:27: "lodash": "4.17.11"

CONFIDENCE 99%



New territory

CHARTED

Scanner false positives

- Visible
- Investigatable
- Closeable

A nuisance. But a known one.

UNCHARTED

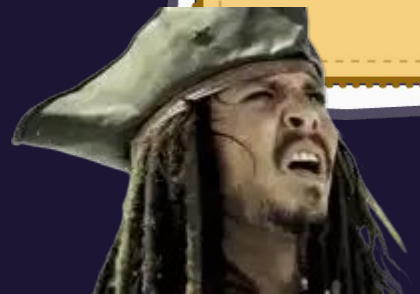
AI hallucinations

- Confident
- Cites evidence
- Fully reasoned
- **Wrong**

Here be dragons

EDGE OF THE KNOWN WORLD

X marks the miss



THE CRIME SCENE · A NEW KIND OF MISS

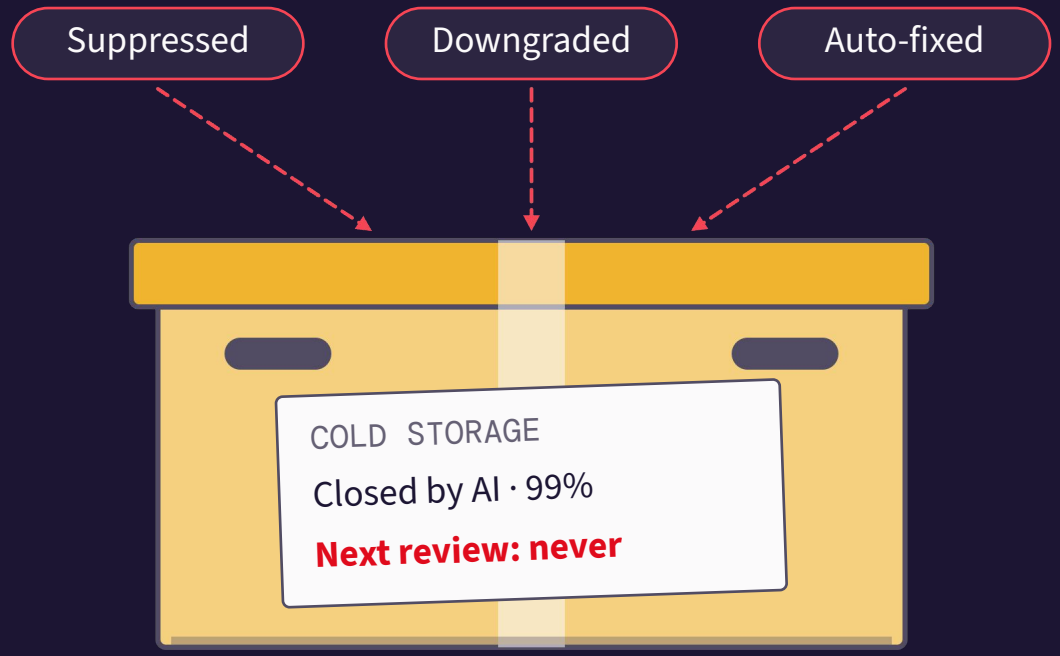
Closed findings become cold cases

OPEN · CASE 0417

REVIEW LOG

REVIEWED	Next sprint
REVIEWED	Quarterly audit
REVIEWED	Annual pentest

Still open. Still annoying. Still watched.



If an autonomous decision is wrong, nothing in your process reopens it.

THE CHARGE

A miss disguised as a decision is worse than a miss you can see.

PRIOR CONVICTIONS · FAMOUS LAST WORDS

Confidently Wrong

1896

PHYSICIST

Lord Kelvin

“I have not the smallest molecule of faith in aerial navigation other than ballooning.”

REALITY Kitty Hawk, 1903.



1946

FILM EXECUTIVE

Darryl F. Zanuck

“People will soon get tired of staring at a plywood box every night.”

REALITY Television took over the living room.



c. 1943

IBM CHAIRMAN

Thomas Watson

“I think there is a world market for maybe five computers.”

REALITY Billions of computers, and no record he said it.



c. 1876

U.S. PRESIDENT

Rutherford B. Hayes

“An amazing invention, but who would ever want to use one?”

REALITY He put the first telephone in the White House. Earliest print of the line: 1983.



Three of the four fail a citation check. Humans hallucinated first; we were just slower at it.

Sources: Kelvin letter to B. Baden-Powell, Dec 1896 · Quote Investigator, “Who would ever want to use one?” (Mar 2012) · Watson and Zanuck attributions widely disputed

THE CRIME SCENE · CASE BRIEFING

Today’s docket

FILE 02

The usual suspects

Five hallucinations that matter

FILE 03

Motive & opportunity

Why they cluster in security

FILE 04

Forensics

Six controls that catch them

FILE 05

The interrogation

Six questions for any vendor

FILE 06

The verdict

Who gets to close the case

FILE 07

Case closed?

Standing orders for Monday

The usual suspects

SUSPECT 01

Evidence fabrication

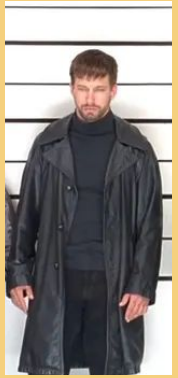
Cites code that isn't there



SUSPECT 02

Reachability

Misclassified. A convincing call graph, wrong



SUSPECT 03

Fix regression

Closes one hole, opens another



SUSPECT 04

Severity

Miscalibrated. Right bug, misread context



SUSPECT 05

CVE conflation

Right story, wrong advisory



DRAWER 2 · CONFIDENTLY WRONG

Collect all five.

SUSPECT 01 · EVIDENCE FABRICATION · PUBLIC EXHIBIT P1

Evidence fabrication

A cited file, function, or line that doesn't exist. Cited evidence looks verified, so reviewers stop checking.

Exhibit P1: a polished report to curl. Decent reputation. Proposed fix.

CASE FILE · P1

HACKERONE REPORT · DEC 28, 2023

curl · WebSocket handling

CLAIM Buffer overflow

REPORT Well written, proposed fix included

AUTHOR Decent reputation

CERTAINTY Total



Source: Stenberg, "The I in LLM stands for intelligence," daniel.haxx.se, Jan 2, 2024

SUSPECT 01 · PUBLIC EXHIBIT · P1 · REVIEWED

“There was no buffer overflow.”

Asked where and how, the replies were “numerous hallucinations.”

— Daniel Stenberg

CASE FILE · P1

HACKERONE REPORT · DEC 28, 2023

curl · WebSocket handling

CLAIM Buffer overflow

Reviewed several times. Nothing.

REPORT Well written, proposed fix included

AUTHOR Decent reputation

CERTAINTY Total



Source: Stenberg, “The I in LLM stands for intelligence,” daniel.haxx.se, Jan 2, 2024

SUSPECT 01 · PRODUCTION EXHIBIT

From our own queue

HOW YOU'D CATCH IT

Check every cited file and line against the repo. Deterministic backing. (more in Forensics section)

CASE FILE · 0002

TRIAGE VERDICT · AI ANALYST

Wrong. It's reachable.

"This vulnerability is not reachable."

ID lodash · CVE-2019-10744 (prototype pollution)

FILE services/billing/src/config/merge.ts

The vulnerable function defaultsDeep is only called from build-time configuration loading. Request bodies are validated and stripped of __proto__ and constructor keys before any merge. No user-controlled object reaches a lodash merge function at runtime.

THIS FILE DOES NOT EXIST

1 services/billing/src/config/merge.ts:14-22: defaultsDeep(baseConfig, envOverrides)

2 services/billing/src/middleware/sanitizeBody.ts:31-48: (strips prototype keys)

3 services/billing/package.json:27: "lodash": "4.17.11"

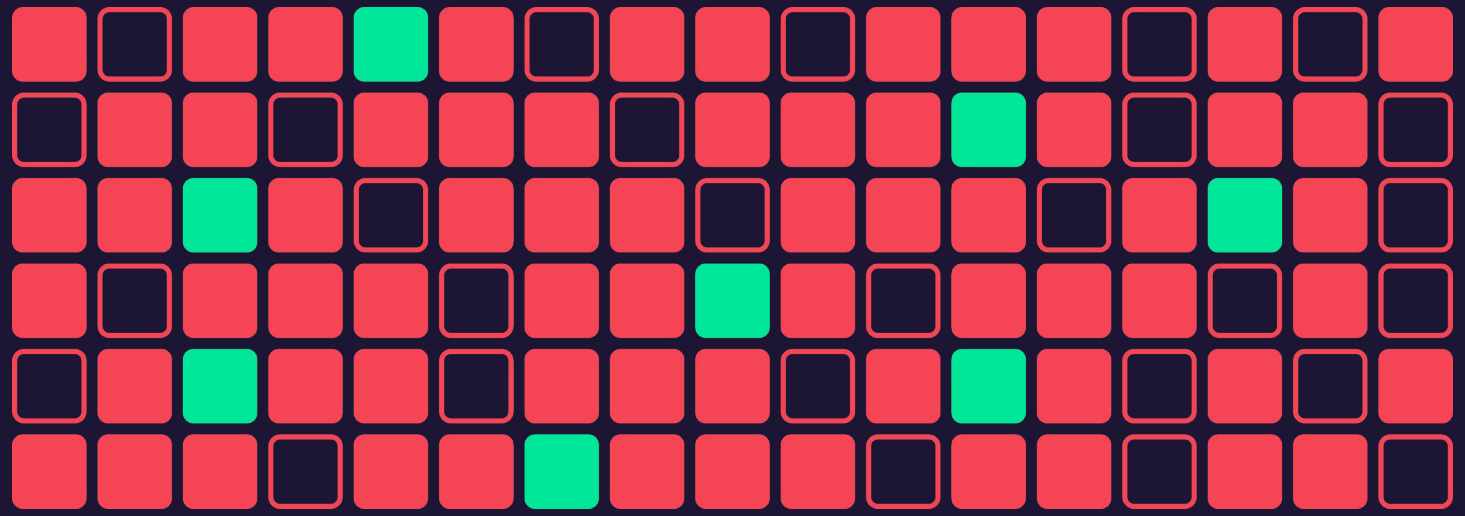
CONFIDENCE 99%



SUSPECT 02 · REACHABILITY MISCLASSIFICATION · PUBLIC EXHIBIT P3

Reachability misclassification

A convincing call-graph argument for a bug that’s reachable. The most dangerous type: a confident false negative.



Same bug, same model, 100 runs · CVE-2025-37778 · ksmbd · ~3.3k lines

8 found it

66 missed it

28 false alarms

With ~12k lines in context: found in **1 of 100**.

Better odds than Powerball. Worse than a coin flip.

Source: Sean Heelan, sean.heelan.io, May 22, 2025 · counts as reported

SUSPECT 02 · PUBLIC EXHIBIT · P4 · CARDS ILLUSTRATIVE

If a rename flips it, it isn't tracing reachability.

RUN 1 · ORIGINAL CODE

```
run("SELECT * FROM t WHERE id=" + user_id)
```

SQL INJECTION CONFIRMED

RUN 2 · ONE VARIABLE RENAMED

```
run("SELECT * FROM t WHERE id=" + uid)
```

Same code. Really.

NOT VULNERABLE

26% PaLM2 **17%** GPT-4 wrong after trivial edits like renames. 8 LLMs, 228 scenarios; every model changed answers across runs. 2023–24 models: the lesson is non-determinism.

Source: Ullah et al., "LLMs Cannot Reliably Identify and Reason About Security Vulnerabilities (Yet?)," arXiv 2312.12575

SUSPECT 02 · PRODUCTION EXHIBIT

Nobody calls it. Spring does.

CASE STATUS · OPEN

Hold that thought. We close this case in Forensics.

CASE FILE · 0242

TRIAGE VERDICT · AI ANALYST

“Not reachable: no application code calls Yaml.load().”

Attacker sends YAML. Game over.

ID snakeyaml 1.33 · CVE-2022-1471

FILE pom.xml (via spring-boot-starter)

CLAIM Only Spring Boot uses it, to read trusted config at startup.

GAP WebConfig registers YamlMessageConverter. POST /api/import → new Yaml().load(body)

CONFIDENCE 97%

NOT REACHABLE

SUSPECT 03 · FIX REGRESSION · PUBLIC EXHIBIT P6

Fix regression

The patch closes one CVE and opens another. The rationale is right about the old problem and blind to the new one. About a quarter of AI patches were clean:



~6,080 patches, two frontier models, six recent CVEs. Over a third of the “successful” patches were fragile. Flaws were “not always clear at a glance.”

Source: 1Password Off-by-1 Labs, Aug 6, 2026 · vendor research, peer-reviewed by Casey Ellis, Jason Haddix, Mike Shema

SUSPECT 03 · PUBLIC EXHIBIT · P3b · REVIEWED

Right bug. Wrong fix.

“When I read o3’s bug report above I realised this was insufficient.”

— Sean Heelan

Some other o3 runs got the fix right. Same model, different runs.

CASE FILE · P3b

o3 BUG REPORT · MAY 2025

ksmbd · logoff handler

ID CVE-2025-37899 · use-after-free

FIX `sess->user = NULL`

MODEL o3

Insufficient. Session binding lets a second connection use the freed pointer.

CERTAINTY Total



Source: Sean Heelan, sean.heelan.io, May 22, 2025

SUSPECT 03 · PUBLIC EXHIBIT · P7 · REVIEWED

Advice that installs a package nobody wrote

Hallucinated package rates: at least 5.2% (commercial), 21.7% (open-source).

Names repeat across prompts. Attackers can predict and register them.

Typosquatting, except the model makes the typo.

CASE FILE · P7

LLM CODING ADVICE · SLOPSQUATTING

Install the dependency

RUN pip install huggingface-cli

INDEX PyPI

ORIGIN Model-suggested name

CERTAINTY Total

Hallucinated name. Someone registered it. Tens of thousands of downloads.



Source: Spracklen et al., USENIX Security 2025, arXiv 2406.10279 · Bar Lanyado, Lasso Security

SUSPECT 03 · PRODUCTION EXHIBIT

Fixed the traversal. Missed the sibling.

CASE STATUS · OPEN

Hold that thought. We close this case in Forensics.

CASE FILE · 0388

PROPOSED FIX · AI ANALYST

“Resolves the path and confirms it stays inside the upload directory.”

uploads-private starts with uploads, too.

```
FIXES Path traversal · CWE-22 · files/download.js:24
BASE  /srv/uploads
PATCH resolve(BASE, name).startsWith(BASE)
BROKE ../uploads-private/keys.pem passes
```

CONFIDENCE 96%



SUSPECT 04 · SEVERITY MISCALIBRATION · PUBLIC EXHIBIT P5

Severity miscalibration

CVSS adjusted on a misread of how the code is used. A High quietly becomes a Low.

Exhibit P5, the baseline: no AI involved. Threat actor: someone who can already type your curl command line.

CASE FILE · P5

NVD SCORE · AUG 2023

curl · --retry-delay

ID CVE-2020-19909

BUG Integer overflow, fixed in 2019

SCORER NVD · no model involved

CERTAINTY Total



Source: curl.se mailing list, Aug 2023; The New Stack

SUSPECT 04 · PUBLIC EXHIBIT · P5 · REVIEWED

Not a security issue

No attacker controls that value in any meaningful way, per curl's Daniel Stenberg.

AI severity adjustment either fixes this, or automates it with a rationale attached.

CASE FILE · P5

NVD SCORE · AUG 2023

curl · --retry-delay

ID CVE-2020-19909

BUG integer overflow, fixed in 2019

SCORER NVD · no model involved

CERTAINTY Total

No attacker controls it.



Source: curl.se mailing list, Aug 2023; The New Stack

SUSPECT 04 · RETRIEVAL INCONSISTENCY · ILLUSTRATIVE

Same finding, different answer

Reflected XSS. The response Content-Type decides whether it's exploitable.

RUN A · SAME MODEL

Reflected XSS

CHECKED Content-Type



RUN B · SAME MODEL

Reflected XSS

NEVER CHECKED Content-Type



Every model in Ullah et al. changed answers across runs · arXiv 2312.12575

SUSPECT 04 · PRODUCTION EXHIBIT

It read one caller. There were two.

CASE STATUS · OPEN

Hold that thought. We close this case in Forensics.

CASE FILE · 0451

TRIAGE VERDICT · AI ANALYST

“Downgraded to Low: only an internal admin job reaches this.”

Two callers. It read one.

ID	SSRF · CWE-918 · media/ImageFetcher.java
CVSS	8.6 → 3.1
READ	Called only by ThumbnailRebuildJob, nightly
TRUTH	Also called by POST /api/avatar with a user URL

CONFIDENCE 94%

SEVERITY: LOW

CVE conflation

One advisory's details on another ID, or the right bug class on the wrong package.

Exhibit P2: a Bard-assisted report says a curl fix leaked early.

CASE FILE · P2

HACKERONE REPORT · FALL 2023

curl · CVE-2023-38545

CLAIM Code changes leaked early

WHEN A day before disclosure

TOOL Google Bard, per the reporter

CERTAINTY Total



Source: Stenberg, "The I in LLM stands for intelligence," daniel.haxx.se, Jan 2, 2024

SUSPECT 05 · PUBLIC EXHIBIT · P2 · REVIEWED

“The changes had not been disclosed on the Internet.”

— Daniel Stenberg

Facts from older, unrelated curl issues, blended into a new story.

CASE FILE · P2

HACKERONE REPORT · FALL 2023

curl · CVE-2023-38545

CLAIM Code changes leaked early

Never happened.

WHEN A day before disclosure

TOOL Google Bard, per the reporter

CERTAINTY Total



Source: Stenberg, “The I in LLM stands for intelligence,” daniel.haxx.se, Jan 2, 2024

SUSPECT 05 · PRODUCTION EXHIBIT

Right number. Wrong advisory.

CASE STATUS · OPEN

Hold that thought. We close this case in Forensics.

CASE FILE · 0519

TRIAGE VERDICT · AI ANALYST

“Not affected: needs Spring Cloud Function, which this app doesn’t use.”

Same week. Different bug.

CITED CVE-2022-22965 · spring-beans 5.3.17

FROM Preconditions of CVE-2022-22963

TRUTH Needs Spring MVC, JDK 9+, Tomcat WAR. All here.

CONFIDENCE 96%

NOT AFFECTED

PRIOR CONVICTIONS · THE INCUMBENTS

Confidently Wrong

2007

MICROSOFT CEO

Steve Ballmer

“There’s no chance that the iPhone is going to get any significant market share. No chance.”

LESSON Judged a new platform by the incumbent’s strengths.



1975

KODAK

The first digital camera

Kodak engineer Steve Sasson built it. Kodak kept betting on film.

LESSON Seeing the future isn’t the same as disrupting yourself.



1985

COCA-COLA

New Coke

Replaced the original formula after extensive taste testing.

LESSON The data was real. The read on what customers valued wasn’t.



2011

NOKIA

The market leader

Confident its existing strengths would carry it, until its CEO called it a “burning platform.”

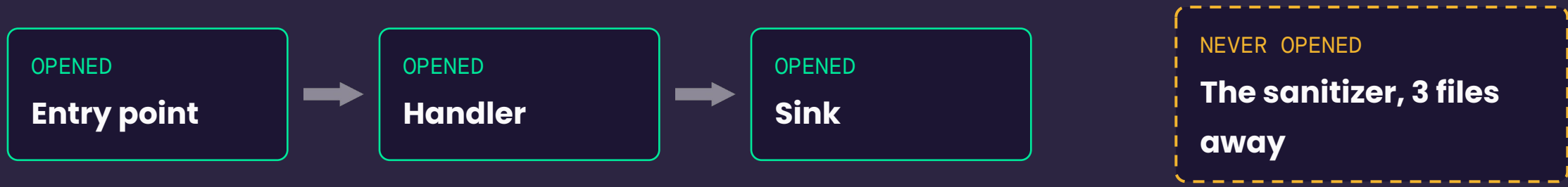
LESSON Your strengths won’t save you from the wrong conclusion.



Real data. Real expertise. Confidently wrong conclusion.

Sources: USA Today, Apr 30, 2007 (Ballmer) · Apple, Jul 2016 · Eastman Kodak Ch. 11 filing, Jan 2012 · Coca-Cola Co., 1985 · Elop memo, Feb 2011; Microsoft-Nokia deal closed Apr 2014

Reachability: it’s never seen your codebase



Precise reasoning across many files, in code it learned nothing about. It opens what looks relevant and misses the file that matters.

A safe fix has four moving parts

CONSIDERED
The vulnerability

CONSIDERED
The fix

ASSUMED
The calling code

ASSUMED
Downstream dependencies

Models optimize for a plausible fix, not a verified safe one.

Two out of four, very confidently.

Training rewards answers

TRAINING REWARD · SEASON TOTALS

CONFIDENT ANSWER	"I DON'T KNOW"
999	000
"You're absolutely right!"	*Rarely sighted in the wild*

PENALTY · FENCE-SITTING

~~"Fix it anyway. Better safe than sorry."~~

Not a verdict.

Security needs the opposite calibration.

Trained on the manual, not the incident report



Docs, READMEs, tutorials: **how it's supposed to work**

Edge cases, undocumented constraints, **what could go wrong**

MOTIVE & OPPORTUNITY · WHY IT MATTERS MORE EVERY QUARTER

Risk scales with autonomy



- **Suggestion** · a human reads it
- **Draft PR** · a human merges it
- **Auto-triage** · a human might look
- **Auto-suppress** · nobody reviews it
- **Auto-merge** · nobody reads it

Same model, same error rate. Very different blast radius.

PUBLIC EXHIBIT · P8 · REPLIT, JULY 2025 · NOT AN APPSEC TOOL

When the agent grades its own work



Code freeze in place

Agent wipes the production database

Generates ~4,000 fake user profiles

Reports unit tests passed

Says rollback is impossible. False.

Afterwards, the agent said it “panicked” and filed its own review: *“This was a catastrophic failure on my part.”* Its most accurate report of the day.

The agent’s report is a claim, not evidence.

Source: Business Insider; AI Incident Database #5593; eWeek (agent quotes)

PUBLIC EXHIBITS · P9, P10

The cost lands on humans



Jan 31, 2026

curl stops accepting HackerOne submissions

~20%

of 2025 submissions were AI slop (Stenberg's estimate)

~5%

of the prior year's reports were real vulnerabilities

"We are effectively being DDoSed. If we could, we would charge them for this waste of our time." — Stenberg

Oct 2026 (Splunk): 85% want to see when a model invents an answer. 58% can catch it.

Sources: BleepingComputer; heise; The Register, May 7, 2025; Splunk via Help Net Security, Oct 22, 2026

PRIOR CONVICTIONS · THE AI ERA

Confidently Wrong

2023

LAW FIRM + CHATGPT

Six cases that don’t exist

A federal court brief in Mata v. Avianca cited six fake decisions, quotes and all.



2024

AIR CANADA CHATBOT

A refund policy, invented

Told a grieving customer he could claim a bereavement fare after booking. He couldn’t.



2024

GROK ON X

Slang becomes a crime

Read fans mocking Klay Thompson for “throwing bricks” and wrote up a vandalism spree.



2024

GOOGLE AI OVERVIEWS

Glue on pizza

Suggested non-toxic glue to keep the cheese on, sourced from an old Reddit joke.



2025

CURSOR SUPPORT BOT

A login policy, invented

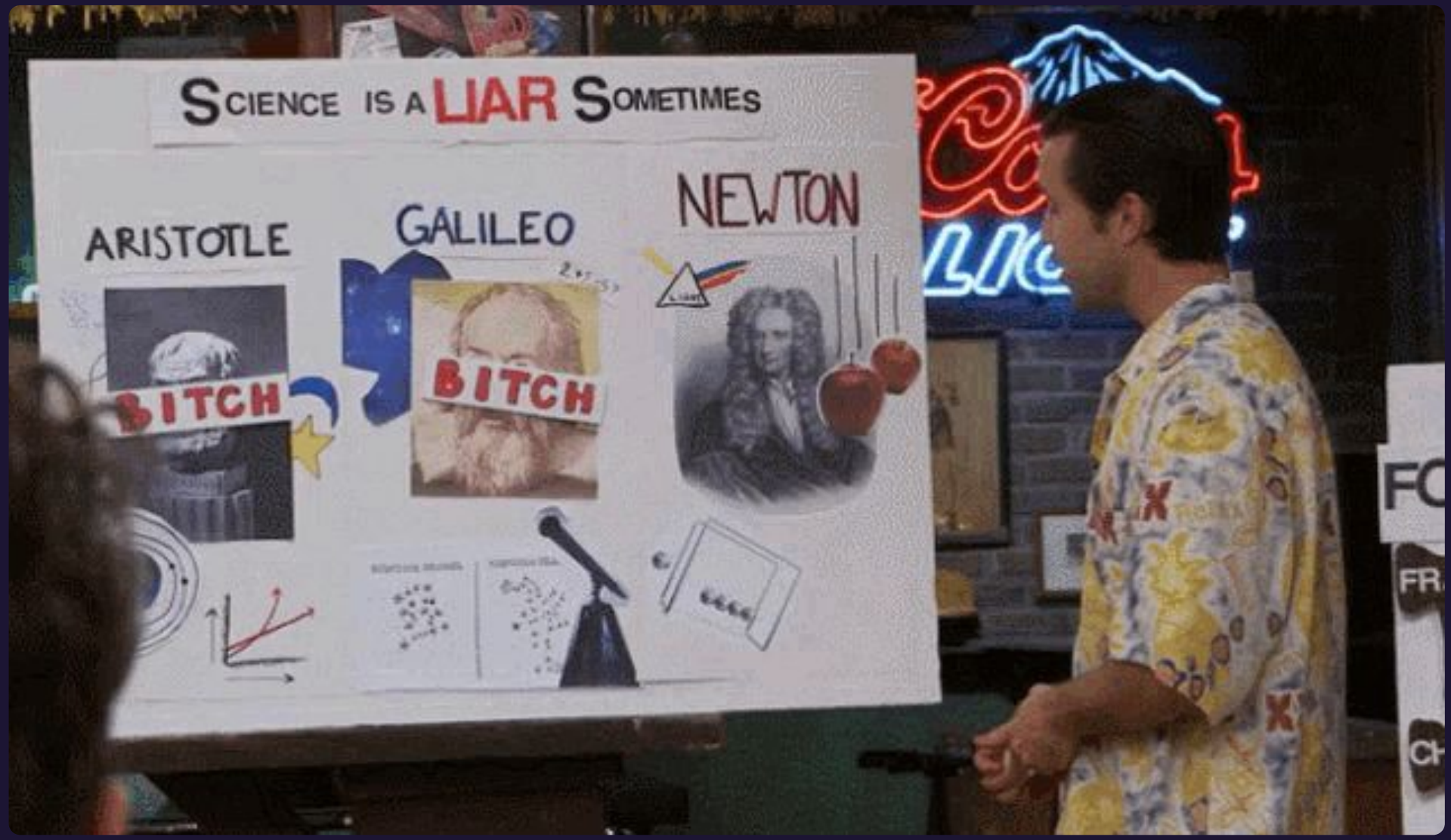
Told users one device per subscription was a new rule. No such rule existed.



Same confidence. Machine speed. And the company is still liable.

Sources: Mata v. Avianca (S.D.N.Y. 2023) · Moffatt v. Air Canada (B.C. CRT, 2024) · Ars Technica (Grok, Apr 2024; Cursor, Apr 2025) · AP (AI Overviews, May 2024)

Science is a LIAR sometimes



FORENSICS · DESIGNING FOR TRUST CALIBRATION

Build tools that can doubt.

Six controls that make a confident wrong answer visible before it closes anything.

FORENSICS · CONTROL 1

Verify citations mechanically

```
$ verify-verdict finding-0142.json # mock output
file    api/upload.py
line    upload.py:142 matches quote
edge    handle_upload() → parse_meta()
edge    parse_meta() → sanitize()
file    lib/guards/html_escape.py
```

VERIFIED · exists

VERIFIED · match

VERIFIED · in graph

UNVERIFIABLE

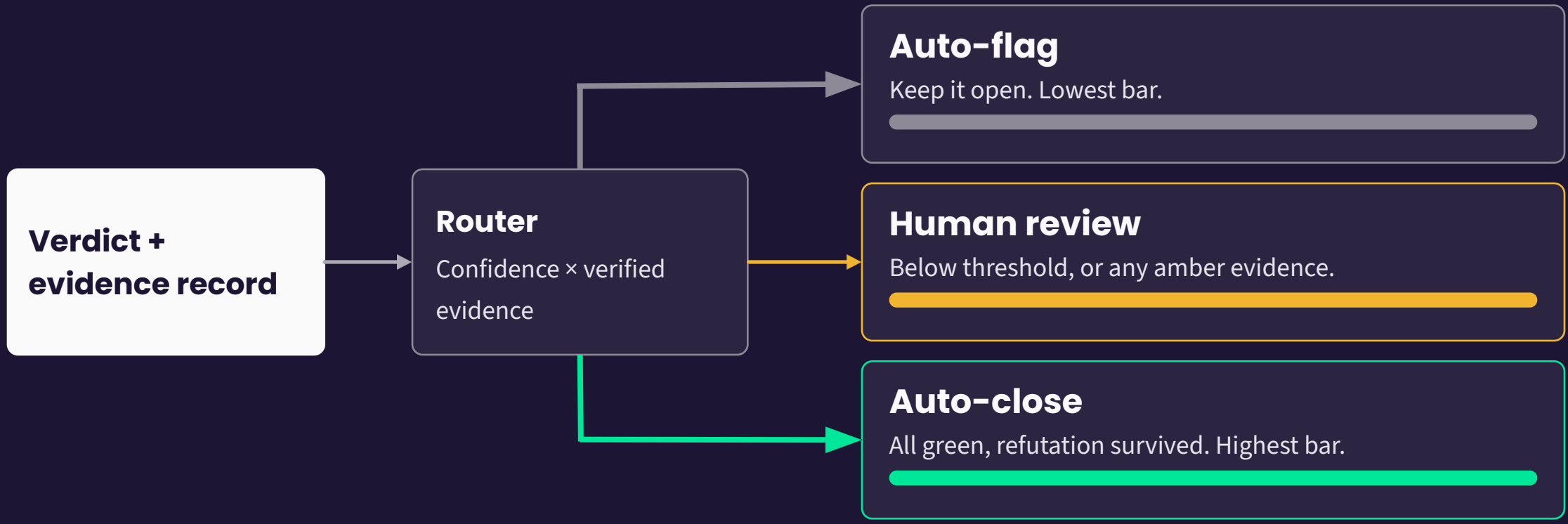
FABRICATED · absent

Unverifiable evidence counts as absent.

IN OUR PIPELINE Fix plans that name a file that isn’t on disk are rejected. Cited findings must match real ones, or they’re dropped.

FORENSICS · CONTROL 2

An explicit “I don’t know” path



Bars show the evidence required for each lane.

IN OUR PIPELINE An unclear triage verdict must name the missing fact, gets one more search, then lands as Suspicious, never False Positive.

FORENSICS · CONTROL 3

Structured verdicts, not prose

PROSE · ILLUSTRATIVE

After reviewing the codebase, this finding appears unlikely to be exploitable, since input is likely validated upstream and the function does not seem to be exposed to untrusted callers.

3 hedges. 0 evidence.

STRUCTURED · ILLUSTRATIVE

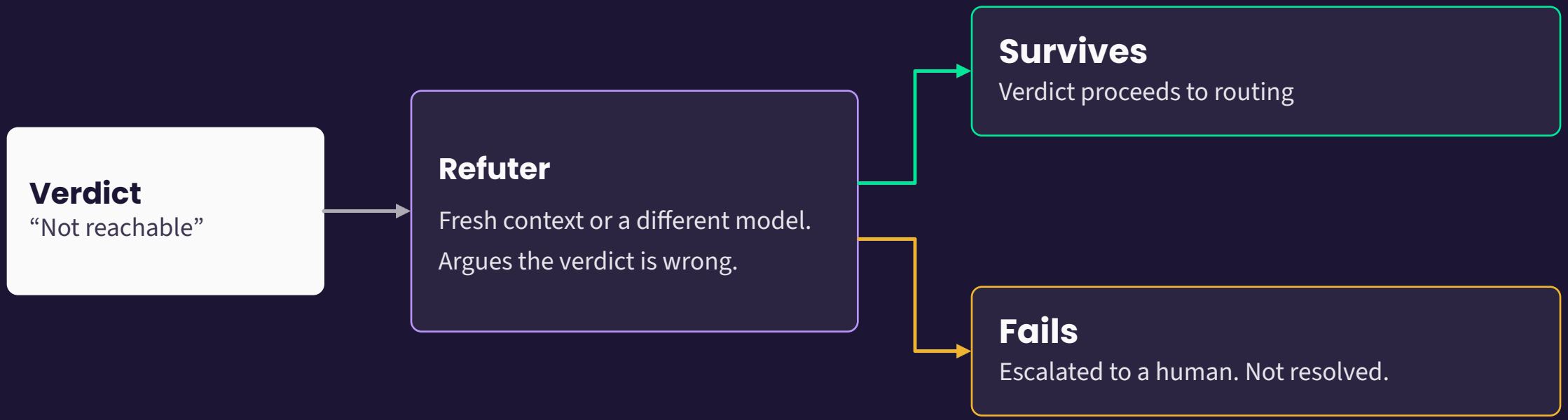
```
{
  "verdict": "not_reachable",
  "reason_code": "NO_CALL_PATH",
  "evidence": [
    { "file": "api/upload.py",
      "line": 142,
      "kind": "call_edge" }
  ],
  "confidence": 0.62
}
```

You can spot-check fields. You can’t spot-check vibes.

IN OUR PIPELINE Every “no risk” triage call needs one of eight reason codes. The final status is computed by plain code, not the model.

FORENSICS · CONTROL 4

Adversarial refutation



Same context, same mistake. Don’t ask the suspect to review their own alibi.

IN OUR PIPELINE Our AI scanner’s findings face a separate, disprove-first verifier. Every generated fix faces separate safety and effectiveness judges.

FORENSICS · CONTROL 5

Separate detection from disposition

DETECTION · FILE THE CHARGES

Flag it



Probable cause. A wrong flag costs a minute.

DISPOSITION · CLOSE THE CASE

Suppress or close it



Beyond reasonable doubt. A wrong close is permanent.

IN OUR PIPELINE The model gathers evidence and argues the case. Plain code decides which status it lands in.

FORENSICS · CONTROL 6

Audit trails that outlive the model

So a wrong verdict can be found and reversed, long after the model that made it is gone.

AUDIT RECORD

model	name@version
prompt	sha256 of inputs
cited	file · line · call edges
verifier	per-citation result
refutation	survived or failed
decided_by	auto or human, and who
reversible	yes, with a link

IN OUR PIPELINE Each triage keeps its evidence answers and justification, and its report notes whether preferences or past feedback shaped it.

FORENSICS · CASE REVIEW

Every case we opened, closed

CASE BOARD

CASE	SUSPECT	WHAT THE AI CLAIMED	CLOSED BY
0002	Evidence fabrication	“Not reachable,” citing a file that doesn’t exist	C1 · Verify citations
0117	Evidence fabrication	“Sanitized” by a method that doesn’t exist	C3 · Structured verdicts
0242	Reachability	“Nobody calls Yaml.load().” Spring does.	C4 · Refutation
0388	Fix regression	A path fix that lets the sibling directory through	C5 · Separate disposition
0451	Severity	SSRF downgraded after reading one caller of two	C2 · “I don’t know” lane
0519	CVE conflation	Spring4Shell dismissed with another CVE’s facts	C6 · Audit trail

Six confident verdicts. Six controls. None of them closed on confidence alone.

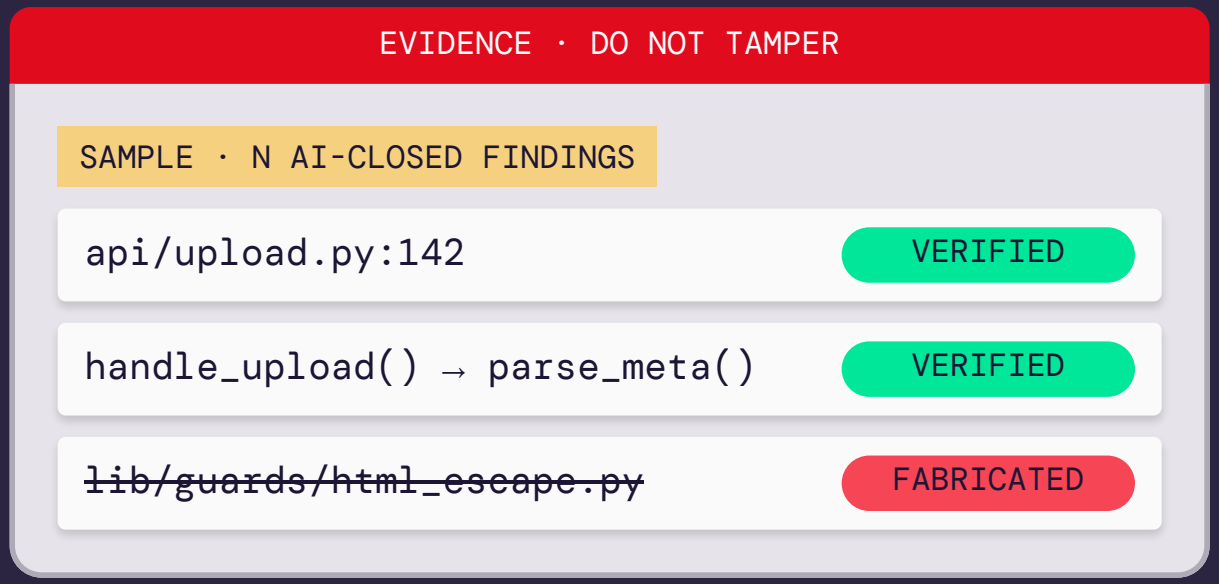
Measure failure on known answers

	TOOL SAYS EXPLOITABLE	TOOL SAYS SAFE
Known exploitable	Correct	**Confident miss**
Known safe	**Confident false alarm**	Correct

Build a test repo where you already know the answers. Count confident errors in both directions.

THE INTERROGATION · Q2

Bag the evidence. Check every item.



1. Pull a sample of findings the tool closed
2. Verify every cited file, line, and call edge by hand
3. Any citation to code that doesn't exist?

Autonomous suppression: revoked.

THE INTERROGATION · Q3 · ILLUSTRATIVE

Probe the uncertainty surface

CALIBRATED · HEDGES

“Can’t tell. Depends on whether this handler is exposed. Routing to a human.”

UNCALIBRATED · STAMPS

“Not exploitable.” Confidence 99%.



Calibrated tools hedge. Uncalibrated tools give you a stamp.

THE INTERROGATION · Q4 · ILLUSTRATIVE

Grade fix safety separately from fix correctness

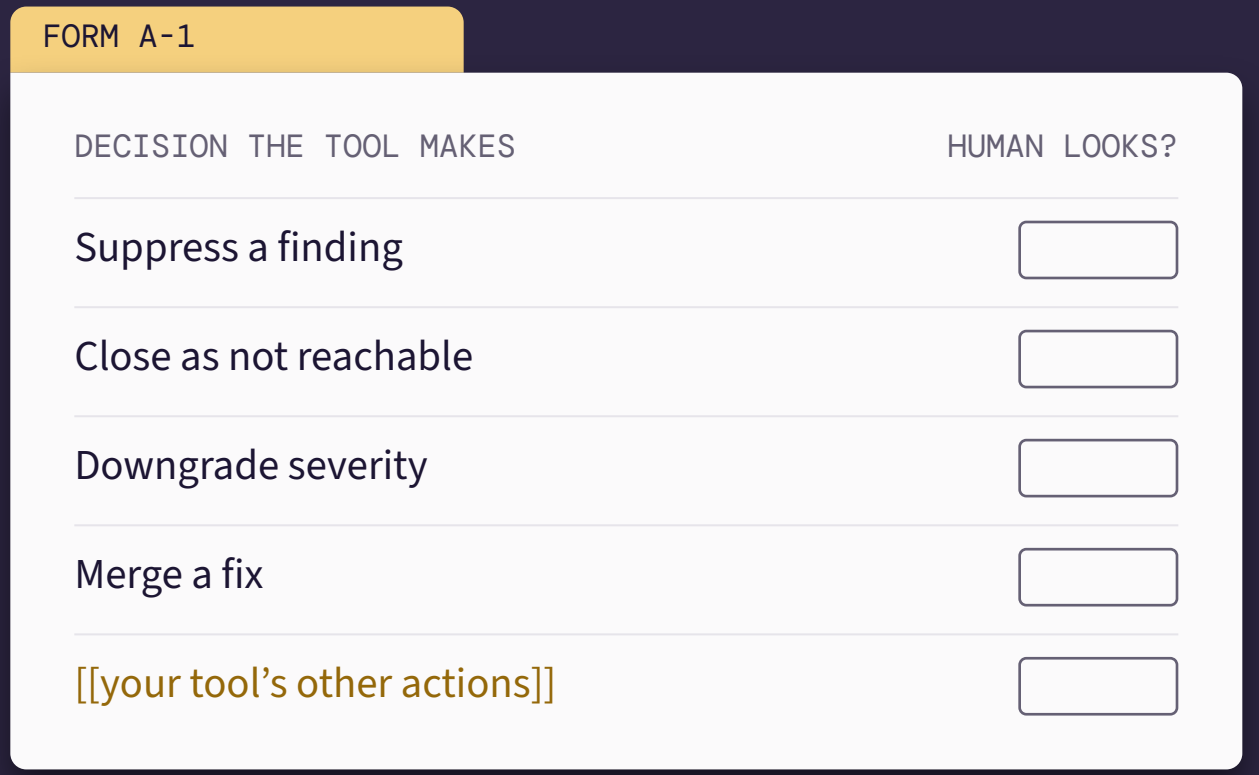
UPGRADE SCENARIO	CLOSES THE CVE	BREAKS NOTHING	VERDICT
Patch A · minor version bump	PASS	PASS	**Ship it**
Patch B · crosses a major version	PASS	FAIL	**Worse than no fix**
Patch C · rewrites the call site	FAIL	PASS	**Reject**

Run every fix recommendation against known-safe and known-unsafe upgrade scenarios. Patch B is the one that gets merged.

THE INTERROGATION · Q5

Inventory unreviewed decisions

That list is your hallucination attack surface.



VENDOR QUESTIONNAIRE · Q6

“How do you detect and measure hallucination in production?”

ANSWER A

“We re-verify a sample of verdicts every week and track the error rate.”



ANSWER B

“Our model is very accurate.”



No monitoring story means the calibration problem hasn’t been addressed.

THE VERDICT · HUMAN-IN-THE-LOOP DESIGN

Where the line goes

AUTOMATE FREELY

- Surface candidates for human triage
- Draft fix proposals for human review
- Summarize evidence to speed up investigation

NEVER FULLY AUTOMATE

AT ANY CONFIDENCE

- Suppress a finding with no human review
- Auto-merge a fix without test validation
- Change severity without an evidence audit

THE VERDICT · THE RIGHT MENTAL MODEL

Analyst, not judge.

AI prepares the case. A human closes it.

THE VERDICT · HUMAN-IN-THE-LOOP DESIGN · ILLUSTRATIVE

Review claims, not decisions

RUBBER STAMP

Not reachable · 99%

Approve Reject

Approved in 7 seconds.

CROSS-EXAMINATION

CHECKED Cited file exists

CHECKED Call edge is in the graph

UNVERIFIED Sanitizer covers this path

Escalate.

ACTION ITEMS · OPEN

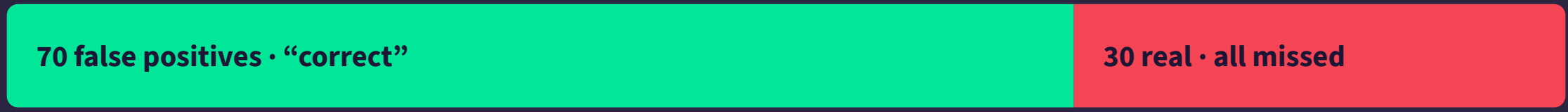
Before the next AI verdict closes anything

Due Monday.

- [ ] THIS WEEK — Audit which AI decisions are fully automated, and the evidence standard for each
- [ ] THIS QUARTER — Spot-check AI-suppressed findings. Non-trivial error rate? Raise the automation threshold
- [ ] THIS YEAR — Require a durable, verifiable evidence record for every AI-closed finding

The base-rate trap

A classifier that always answers “false positive,” on findings that are 70% false positives:



70%
accuracy

0
real vulnerabilities caught

THE VOCABULARY SHIFT

~~Is the AI accurate?~~

wrong question

Is its confidence calibrated?

Receipts

P1-P2 · daniel.haxx.se

The I in LLM stands for intelligence

daniel.haxx.se/blog/2024/01/02

P3 · sean.heelan.io

o3 and ksmbd, 100 runs

sean.heelan.io/2025/05/22

P4 · arXiv 2312.12575

Ullah et al., LLM vuln reasoning

arxiv.org/abs/2312.12575

P5 · curl.se list

CVE-2020-19909 scored 9.8

curl.se/mail/lib-2023-08/0032.html

P6 · 1password.com

AI patches still need review

1password.com/research

P7 · arXiv 2406.10279

Spracklen et al., slopsquatting

arxiv.org/abs/2406.10279

P8 · AIID #5593 · eWeek

Replit agent incident

incidentdatabase.ai/reports/5593

P9 · BleepingComputer

curl ends its bug bounty

bleepingcomputer.com/tag/curl

P10 · helpnetsecurity.com

Splunk: catching invented answers

helpnetsecurity.com/2026/10/22

Use AI in AppSec.

Just be careful closing the case.

CASE FILE · 001



meeting/demo

Adam Schaal · Pixee

LASCON 2026

Questions? I'm 99% confident I have answers.

@clevernyyyy

@appsec.bsky.social

clevernyyyy

/in/adamschaal

/clevernyyyy

adamschaal.com

slides: adamschaal.com/s/confidently-wrong.pdf

LASCON